ĐẠI HỌC ĐÀ NẴNG
TRƯỜNG ĐẠI HỌC BÁCH KHOA
KHOA CÔNG NGHỆ THÔNG TIN
Tel. (+84.0236) 3736949, Fax. (84-511) 3842771
Website: http://dut.udn.vn/khoacntt, E-mail: cntt@dut.udn.vn



BÁO CÁO MÔN HỌC
<TÊN MÔN>

ĐỀ TÀI :

ỨNG DỤNG HỌC MÁY PHÁT HIỆN TẤN CÔNG MẠNG DỰA TRÊN DỮ LIỆU LƯU LƯỢNG MẠNG

Họ tên sinh viên	Mã sinh viên	Nhóm HP
Nguyễn Văn A	102102102	20Nh14

CBHD : <Họ và Tên GV hướng dẫn>

Đà Nẵng, 11/2026

MỤC LỤC

CHƯƠNG 1: CƠ SỞ LÝ THUYẾT 3

1.1. Lưu lượng mạng, flow và đặc trưng theo cửa sổ 3
1.2. Các loại tấn công được xét 3
1.3. Mô hình học máy và chỉ số đánh giá 4
1.4. Bộ dữ liệu sử dụng 4
1.5. Kết chương 5

CHƯƠNG 2: PHÂN TÍCH THIẾT KẾ HỆ THỐNG 6

2.1. PHÁT BIỂU BÀI TOÁN 6
2.2. PHÂN TÍCH HIỆN TRẠNG 6
2.3. PHÂN TÍCH CHỨC NĂNG 7
2.3.1. Đối tượng sử dụng 7
2.3.2. Đọc gói tin, ghép flow và tính đặc trưng 7
2.3.3. Module phát hiện bất thường (Gaussian) 7
2.3.4. Module phân loại tấn công (Random Forest) 7
2.3.5. Module botnet và nhận dạng topology 8
2.3.6. Pipeline offline và cảm biến realtime 8
2.3.7. Công nghệ sử dụng 8
2.4. THIẾT KẾ DỮ LIỆU 9
2.4.1. Sơ đồ tổng thể 9
2.4.2. Bảng flow và bảng cửa sổ host 9
2.4.3. Bảng cảnh báo và nhật ký lần chạy 9
2.5. XÂY DỰNG CHƯƠNG TRÌNH 10
2.5.1. Tổ chức thư mục 10
2.5.2. Nhóm module đọc dữ liệu và tính đặc trưng 10
2.5.3. Nhóm module mô hình 10
2.5.4. Nhóm module chạy và đánh giá 10
2.6. Kết chương 11

CHƯƠNG 3: TRIỂN KHAI VÀ ĐÁNH GIÁ KẾT QUẢ 12

3.1. MÔ HÌNH TRIỂN KHAI 12
3.1.1. Môi trường triển khai 12
3.1.2. Các công cụ sử dụng 12
3.1.3. Cấu hình hệ thống 12
3.2. KẾT QUẢ THỰC NGHIỆM TRÊN BỘ DỮ LIỆU CÔNG KHAI 13
3.2.1. Kịch bản 1: Kiểm tra bộ đọc gói tin 13
3.2.2. Kịch bản 2: Module phát hiện bất thường trên CIC-IDS2017 13
3.2.3. Kịch bản 3: Module phân loại tấn công trên CIC-IDS2017 13
3.2.4. Kịch bản 4: Module botnet trên CTU-13 14
3.2.5. Kịch bản 5: Pipeline offline và cảm biến realtime 14

3.3. KẾT QUẢ THỰC NGHIỆM TRÊN LAB ẢO 15
3.3.1. Kịch bản 1: Mô hình học từ dữ liệu công khai, chạy trên lab 15
3.3.2. Kịch bản 2: Học lại mô hình trên dữ liệu lab 16
3.3.3. Kịch bản 3: Kiểm tra khái quát 17
3.3.4. Kịch bản 4: Cảm biến realtime bắt trực tiếp (demo) 17
3.4. NHẬN XÉT ĐÁNH GIÁ KẾT QUẢ 18
3.5. Kết chương 18

DANH SÁCH HÌNH ẢNH

Hình 3.1. Ma trận nhầm lẫn của hai mô hình phân loại trên tập kiểm tra 14
Hình 3.2. Độ trễ phát hiện của từng đợt tấn công với mô hình học từ dữ liệu công khai 15
Hình 3.3. Báo động giả theo biến thể và module với mô hình học từ dữ liệu công khai 16
Hình 3.4. Trích màn hình demo quét cổng: cảnh báo và phần tổng kết 18

DANH SÁCH TỪ VIẾT TẮT

Từ viết tắt	Giải thích	Diễn giải tiếng Việt
IDS	Intrusion Detection System	Hệ thống phát hiện xâm nhập
NIDS	Network Intrusion Detection System	Hệ thống phát hiện xâm nhập dựa trên lưu lượng mạng
PCAP	Packet Capture	Định dạng file lưu gói tin bắt được
IP	Internet Protocol	Giao thức liên mạng
TCP	Transmission Control Protocol	Giao thức truyền tin cậy, có kết nối
UDP	User Datagram Protocol	Giao thức truyền không kết nối
DoS	Denial of Service	Tấn công từ chối dịch vụ
C&C	Command and Control	Máy điều khiển botnet
P2P	Peer-to-Peer	Mô hình ngang hàng
RF	Random Forest	Mô hình rừng ngẫu nhiên
LR	Logistic Regression	Hồi quy logistic
F1	F1-score	Trung bình điều hòa của precision và recall
AUC	Area Under the Curve	Diện tích dưới đường cong ROC
WSL	Windows Subsystem for Linux	Linux chạy trong Windows
CSV	Comma-Separated Values	Định dạng bảng dạng văn bản

BẢNG PHÂN CÔNG CÔNG VIỆC

TT	Công việc	Người thực hiện
1	Khảo sát dữ liệu, bộ đọc gói tin và log, ghép flow, tính đặc trưng	
2	Gán nhãn, chia tập, module phát hiện bất thường (Gaussian)	
3	Module phân loại tấn công (Random Forest)	
4	Module botnet và nhận dạng topology	
5	Pipeline offline, cảm biến realtime, lab ảo, kiểm thử thực nghiệm, demo	

MỞ ĐẦU

1. Tổng quan về đề tài

Hệ thống phát hiện xâm nhập dựa trên luật chỉ nhận ra những mẫu tấn công đã được mô tả trước. Học máy cho phép học hành vi của lưu lượng mạng từ dữ liệu và phát hiện tấn công dựa trên đặc trưng thống kê của lưu lượng, không cần đọc nội dung gói tin.

Đề tài xây dựng một hệ thống phát hiện tấn công mạng dựa trên dữ liệu lưu lượng mạng, gồm ba module: phát hiện bất thường bằng mô hình Gaussian đa biến; phân loại tấn công (bình thường, quét cổng, từ chối dịch vụ) bằng Random Forest; phát hiện máy nhiễm botnet và nhận dạng kiểu liên lạc của botnet (tập trung hay ngang hàng). Hệ thống chạy được ở hai chế độ: phân tích file PCAP đã thu và giám sát trực tiếp trên card mạng.

2. Mục đích và ý nghĩa của đề tài

2.1. Mục đích

- Xây dựng trọn chuỗi xử lý từ gói tin thô tới cảnh báo: đọc gói, ghép flow, tính đặc trưng, huấn luyện mô hình, chạy offline và realtime.
- Đánh giá ba module trên bộ dữ liệu công khai CIC-IDS2017 và CTU-13.
- Kiểm thử hệ thống trên một mạng thử nghiệm tự dựng, có nhãn chuẩn, đo tỷ lệ phát hiện, độ trễ và báo động giả.

2.2. Ý nghĩa

Đề tài cho thấy cách áp dụng học máy vào giám sát an ninh mạng một cách có kiểm chứng: mọi con số trong báo cáo đều đo được và lặp lại được bằng mã nguồn. Kết quả cũng chỉ ra một điểm thực tế quan trọng: mô hình học từ bộ dữ liệu công khai không tự chuyển sang mạng khác, cần học lại trên chính mạng cần bảo vệ.

3. Phương pháp thực hiện

- Tự viết bộ đọc PCAP và bộ ghép flow bằng Python, đối chiếu từng trường với Wireshark.

- Tính đặc trưng theo từng máy (host) trong cửa sổ thời gian trượt; dùng cùng một đoạn mã cho huấn luyện, chạy offline và realtime.
- Gán nhãn theo lịch tấn công; chia tập huấn luyện, kiểm định, kiểm tra theo thời gian để tránh rò rỉ dữ liệu; tham số và ngưỡng chỉ chọn trên tập kiểm định.
- Dựng lab ảo 7 máy bằng network namespace trên WSL2; mỗi lần chạy có nhật ký ghi giờ tấn công thật để chấm.
- Mỗi quyết định kỹ thuật được ghi lại kèm lý do (73 quyết định); mã nguồn có 444 kiểm thử tự động.

4. Bố cục của báo cáo

Báo cáo bao gồm các phần chính sau:

- Mở đầu.
- Chương 1: trình bày cơ sở lý thuyết về lưu lượng mạng, các loại tấn công được xét, các mô hình học máy và bộ dữ liệu sử dụng.
- Chương 2: trình bày phân tích bài toán, thiết kế các module, thiết kế dữ liệu và tổ chức chương trình.
- Chương 3: trình bày môi trường triển khai, kết quả thực nghiệm trên bộ dữ liệu công khai và trên lab, nhận xét.
- Kết luận và hướng phát triển.

CHƯƠNG 1: CƠ SỞ LÝ THUYẾT

Chương này trình bày các nội dung lý thuyết được dùng trực tiếp trong đề tài: cách biểu diễn lưu lượng mạng, ba loại tấn công được xét, hai mô hình học máy và các chỉ số đánh giá, và hai bộ dữ liệu công khai.

1.1. Lưu lượng mạng, flow và đặc trưng theo cửa sổ

Gói tin là đơn vị nhỏ nhất của lưu lượng. Header của gói cho biết địa chỉ IP nguồn và đích, giao thức, cổng nguồn và đích, độ dài và các cờ TCP. Đề tài chỉ dùng thông tin trong header, không đọc nội dung ứng dụng.

Flow là tập các gói của cùng một kết nối, xác định bởi bộ năm giá trị: IP nguồn, IP đích, cổng nguồn, cổng đích, giao thức. Đề tài dùng flow hai chiều: chiều đi là chiều của bên mở kết nối. Một flow kết thúc khi có cờ FIN hoặc RST (chờ thêm 10 giây), khi không có gói trong 60 giây, hoặc khi dài quá 120 giây.

Cửa sổ host là một khoảng thời gian cố định dùng để gom số liệu của một máy. Đề tài dùng cửa sổ 10 giây trượt mỗi 2 giây cho module bất thường và module phân loại, cửa sổ 120 giây trượt mỗi 10 giây cho module botnet. Trong mỗi cửa sổ tính các đặc trưng như số kết nối, số cổng đích khác nhau, độ đa dạng của cổng đích (entropy), tỷ lệ kết nối không hoàn tất bắt tay ba bước, số byte gửi và nhận.

1.2. Các loại tấn công được xét

- Quét cổng (port scan): một máy thử mở kết nối tới nhiều cổng của máy khác để tìm dịch vụ đang mở. Dấu hiệu: nhiều cổng đích khác nhau trong thời gian ngắn, phần lớn kết nối không hoàn tất.
- Từ chối dịch vụ (DoS): làm máy chủ quá tải. Đề tài xét DoS tầng HTTP của CIC-IDS2017 (Hulk, GoldenEye, Slowloris, Slowhttptest), tải kết nối và SYN flood trong lab. Dấu hiệu: rất nhiều kết nối tới một cổng.
- Botnet: nhiều máy bị nhiễm cùng chịu điều khiển. Kiểu tập trung: các bot gọi về một máy điều khiển. Kiểu ngang hàng: các bot gọi lẫn nhau. Dấu

hiệu thường gặp là gọi định kỳ (beaconing): liên lạc theo chu kỳ đều, mỗi lần ít dữ liệu.

1.3. Mô hình học máy và chỉ số đánh giá

Gaussian đa biến mô tả dữ liệu bình thường bằng vectơ trung bình và ma trận hiệp phương sai. Điểm bất thường của một mẫu là khoảng cách Mahalanobis bình phương tới trung bình; mẫu có điểm vượt ngưỡng bị coi là bất thường. Đề tài biến đổi đặc trưng bằng Yeo-Johnson hoặc log(1 + x) trước khi fit, và ước lượng hiệp phương sai bằng phương pháp co Ledoit-Wolf để ma trận luôn nghịch đảo được.

Random Forest là tập hợp nhiều cây quyết định, mỗi cây học trên một mẫu ngẫu nhiên của dữ liệu và của đặc trưng; kết quả là trung bình xác suất của các cây. Mô hình này chịu được đặc trưng có thang đo khác nhau và quan hệ phi tuyến. Logistic Regression được dùng làm mức chuẩn để so sánh.

Chỉ số đánh giá: precision là phần cảnh báo đúng trong các cảnh báo; recall là phần tấn công bắt được; F1 là trung bình điều hòa của hai chỉ số; macro-F1 là trung bình F1 của các lớp, mỗi lớp nặng như nhau. Với kiểm thử trên lab, đề tài đếm theo đợt tấn công: một đợt được coi là phát hiện khi có ít nhất một cảnh báo đúng loại, trên đúng máy, trong đúng khoảng thời gian.

1.4. Bộ dữ liệu sử dụng

Bảng 1.1. Dữ liệu sử dụng và lý do chọn

Dữ liệu	Dùng cho	Lý do chọn
CIC-IDS2017, thứ Hai, thứ Tư, thứ Sáu	Module bất thường; module phân loại quét cổng, DoS	Có PCAP gốc và lịch tấn công nên chạy được qua bộ trích xuất của đề tài; có đúng hai loại cần: bốn công cụ DoS (thứ Tư) và Nmap (thứ Sáu); thứ Hai chỉ có lưu lượng bình thường
CTU-13, 13 kịch bản	Module botnet	Botnet thật trong mạng trường đại học, có nhãn từng flow, có cả kiểu tập trung và ngang hàng
Lab ảo 7 máy, 177 lần chạy	Kiểm thử thực nghiệm; học lại mô hình cho mạng lab	Cần đo trên mạng tự dựng, có nhãn chuẩn tự ghi và đo được độ trễ realtime

Với CIC-IDS2017, đề tài dùng PCAP chứ không dùng file CSV đặc trưng có sẵn, vì hệ thống realtime phải tính đặc trưng từ gói tin bằng đúng đoạn mã lúc huấn luyện. Với CTU-13, đề tài dùng file flow hai chiều có nhãn vì PCAP đầy đủ của toàn mạng không được công bố.

1.5. Kết chương

Chương này đã trình bày cách biểu diễn lưu lượng bằng flow và cửa sổ host, ba loại tấn công được xét, hai mô hình học máy cùng các chỉ số đánh giá, và các bộ dữ liệu. Chương 2 dùng các nội dung này để thiết kế hệ thống.

CHƯƠNG 2: PHÂN TÍCH THIẾT KẾ HỆ THỐNG

Chương này trình bày bài toán, hiện trạng dữ liệu và điều kiện thực hiện, thiết kế của từng module, các bảng dữ liệu trung gian và tổ chức mã nguồn.

2.1. PHÁT BIỂU BÀI TOÁN

Đầu vào: lưu lượng của một mạng nội bộ, dưới dạng file PCAP hoặc gói tin bắt trực tiếp từ cổng mirror của switch. Đầu ra: danh sách cảnh báo theo từng máy và từng cửa sổ thời gian, trả lời ba câu hỏi:

- Máy này có hành vi khác bình thường không? (module bất thường)
- Nếu là tấn công thì thuộc loại nào: quét cổng hay DoS? (module phân loại)
- Máy này có phải bot không, và nhóm bot liên lạc kiểu tập trung hay ngang hàng? (module botnet)

Ràng buộc: huấn luyện và chạy thật phải dùng cùng cách tính đặc trưng; đặc trưng không được dùng dữ liệu tương lai; lưu lượng thử nghiệm phải vô hại và không ra khỏi mạng lab.

2.2. PHÂN TÍCH HIỆN TRẠNG

- Dữ liệu công khai có đủ cho quét cổng, DoS tầng HTTP và botnet, nhưng là dữ liệu của mạng khác, thu năm 2011 và 2017.
- Nhóm chưa có 7 máy thật và switch có cổng mirror, nên mạng thử nghiệm được dựng ảo bằng network namespace trên WSL2. Gói tin vẫn là gói thật của nhân Linux, Nginx và Nmap.
- Lab không được chạy mã độc, nên bot trong lab là chương trình mô phỏng chỉ gọi định kỳ, không gây hại.

2.3. PHÂN TÍCH CHỨC NĂNG

2.3.1. Đối tượng sử dụng

Người quản trị mạng hoặc người giám sát an ninh: chạy cảm biến trên máy giám sát, đọc file cảnh báo và file sự kiện. Người phát triển: huấn luyện lại mô hình trên dữ liệu của mạng cần bảo vệ.

2.3.2. Đọc gói tin, ghép flow và tính đặc trưng

Bộ đọc PCAP/PCAPNG và phần bóc header Ethernet, VLAN, IPv4, IPv6, TCP, UDP, ICMP được tự viết bằng thư viện chuẩn của Python. Gói không đọc được bị bỏ qua có thống kê. Bộ ghép flow xử lý từng gói theo thứ tự thời gian, chỉ dựa vào gói đã tới, nên chạy được cả offline lẫn realtime và cho cùng kết quả.

Kết nối TCP không nhận được trả lời bắt tay trong thời gian quan sát được đánh dấu là không hoàn tất. Đây chỉ là một đặc trưng, không tự động gán nhãn quét cổng.

2.3.3. Module phát hiện bất thường (Gaussian)

- Đầu vào: 14 đặc trưng của cửa sổ host 10 giây, chọn theo quy tắc trên tập huấn luyện.
- Biến đổi Yeo-Johnson hoặc log(1 + x); fit trung bình và hiệp phương sai Ledoit-Wolf trên cửa sổ bình thường.
- Điểm là khoảng cách Mahalanobis bình phương; ngưỡng chọn trên tập kiểm định theo F1 ổn định.

2.3.4. Module phân loại tấn công (Random Forest)

- Ba lớp: benign, port_scan, dos, trên cửa sổ host 10 giây.
- So sánh Logistic Regression và Random Forest trên cùng dữ liệu và tiền xử lý; chọn Random Forest.
- Cửa sổ có dưới 20% flow tấn công được coi là mơ hồ và không dùng để học.

2.3.5. Module botnet và nhận dạng topology

- Dựng đồ thị liên lạc có hướng giữa các máy trong cửa sổ 120 giây, trượt mỗi 10 giây.
- Tính 19 đặc trưng đồ thị cho mỗi máy (số máy liên lạc, bậc vào, bậc ra, mức tương hỗ, mức tập trung) và đặc trưng gọi định kỳ: cần ít nhất 5 lần quan sát trong 600 giây, coi là đều khi hệ số biến thiên không quá 0,3.
- Random Forest quyết định máy có phải bot không; sau đó một quy tắc quyết định topology. Với lab, quy tắc là: máy bị nghi là ngang hàng khi trong cùng cửa sổ nó có flow trực tiếp với một máy bị nghi khác; còn lại là tập trung.

2.3.6. Pipeline offline và cảm biến realtime

- Pipeline offline: một lệnh nhận file PCAP, chạy ba module bằng mô hình đã lưu, ghi cảnh báo, điểm và sự kiện.
- Ba chế độ kết hợp: độc lập (ba module chấm mọi máy), tuần tự và kết hợp. Lab dùng chế độ độc lập.
- Cảnh báo lặp của cùng module, cùng nhãn, cùng máy được gộp thành một sự kiện.
- Cảm biến realtime bắt gói bằng socket AF_PACKET, không dùng thư viện ngoài; luồng đọc đẩy gói vào hàng đợi có giới hạn, luồng xử lý chấm khi cửa sổ đóng; chạy nền bằng systemd và dừng êm theo tín hiệu.

2.3.7. Công nghệ sử dụng

Bảng 2.1. Công nghệ sử dụng

Thành phần	Công nghệ
Ngôn ngữ	Python 3.13
Học máy	scikit-learn 1.8 (Random Forest, Logistic Regression, Ledoit-Wolf), NumPy, pandas
Đọc gói tin, ghép flow	Tự viết bằng thư viện chuẩn của Python
Đối chiếu	Wireshark/TShark
Lab ảo	WSL2 Ubuntu, network namespace, bridge, tc mirror, tcpdump

Sinh lưu lượng	Nginx (máy chủ web), Nmap (quét cổng), hping3 (SYN flood), script Python (tải kết nối, bot mô phỏng)
Triển khai	systemd, file cấu hình YAML
Kiểm thử	unittest, 444 kiểm thử tự động

2.4. THIẾT KẾ DỮ LIỆU

Hệ thống không dùng cơ sở dữ liệu quan hệ. Dữ liệu trung gian và kết quả là các bảng CSV có mô tả cấu trúc đi kèm.

2.4.1. Sơ đồ tổng thể

```
gói tin --> bảng flow --> bảng cửa sổ host --> gán nhãn, chia tập --> mô hình
                |                                                  --> bảng cảnh báo --> bảng
sự kiện
                +--> đồ thị 120 giây --> đặc trưng botnet
```

2.4.2. Bảng flow và bảng cửa sổ host

Bảng flow: mỗi kết nối một dòng, gồm bộ năm giá trị, thời điểm bắt đầu và kết thúc, số gói và số byte mỗi chiều, cờ TCP, trạng thái bắt tay. Bảng cửa sổ host: mỗi máy trong mỗi cửa sổ 10 giây một dòng. Mỗi bảng có file mô tả đơn vị, kiểu và vai trò của từng cột, và file ghi nguồn gốc (file PCAP, tham số, phiên bản mã).

2.4.3. Bảng cảnh báo và nhật ký lần chạy

Bảng 2.2. Các cột của bảng cảnh báo (dùng chung cho ba module)

Cột	Ý nghĩa
module	Module phát cảnh báo: anomaly, attack_classification, botnet_topology
label	Nhãn: anomaly, port_scan, dos, suspect_host
window_start, window_end	Cửa sổ thời gian của cảnh báo
src_ip, dst_ip	Máy bị cảnh báo và máy liên quan (nếu có)
score, threshold	Điểm của mô hình và ngưỡng
run_id, detail	Mã lần chạy và thông tin thêm, ví dụ xác suất từng lớp
created_at	Giờ thật lúc cảnh báo được phát

Nhật ký lần chạy là file JSON do bộ chạy kịch bản của lab ghi: giờ bắt đầu và kết thúc của bản thu, và với mỗi tấn công là loại, máy nguồn, máy đích, giờ bắt đầu,

giờ kết thúc, lệnh đã chạy. Bộ chạy không đọc kết quả mô hình, nên nhãn chuẩn độc lập với mô hình.

2.5. XÂY DỰNG CHƯƠNG TRÌNH

2.5.1. Tổ chức thư mục

Bảng 2.3. Tổ chức thư mục

Thư mục	Nội dung
src/nids	Mã nguồn của hệ thống (khoảng 45 module)
config	default.yaml (mô hình học từ CIC-IDS2017, CTU-13), lab.yaml (mô hình học trên lab), bảng kê dữ liệu
models	Mô hình đã lưu kèm thông tin nguồn gốc; models/lab là bộ mô hình của lab
scripts	Dựng lab ảo, chạy kịch bản, sinh lưu lượng, cài đặt, demo
tests	Kiểm thử tự động
deploy	File dịch vụ systemd
demo	File .bat chạy demo và hướng dẫn
docs	Tài liệu từng task, báo cáo từng chặng, nhật ký quyết định, hình và số liệu kết quả

2.5.2. Nhóm module đọc dữ liệu và tính đặc trưng

- Đọc PCAP/PCAPNG và bóc header; đọc access log Nginx.
- Ghép flow, tính đặc trưng flow và cửa sổ host, xuất bảng (feature_export).
- Gán nhãn theo lịch tấn công (labeling), chia tập theo thời gian (splits).

2.5.3. Nhóm module mô hình

- Gaussian (module bất thường), classifier (module phân loại), botnet (đồ thị, gọi định kỳ, phát hiện bot, topology).
- hoc_lai_lab: học lại ba module trên các lần chạy train của lab và ghi config/lab.yaml.

2.5.4. Nhóm module chạy và đánh giá

- pipeline (offline), realtime (cảm biến), cam_bien (kiểm tra mirror hai chiều).

- thuc_nghiem, thuc_nghiem_lab: chấm theo nhật ký lần chạy, tổng hợp độ trễ, bỏ sót, báo động giả, hiệu năng.
- scripts/lab_ao.py: dựng lab ảo, chạy kịch bản, ghi nhật ký.

2.6. Kết chương

Chương này đã trình bày bài toán, thiết kế ba module, pipeline offline, cảm biến realtime, các bảng dữ liệu và tổ chức mã nguồn. Chương 3 trình bày kết quả triển khai và thực nghiệm.

CHƯƠNG 3: TRIỂN KHAI VÀ ĐÁNH GIÁ KẾT QUẢ

Chương này trình bày môi trường triển khai, kết quả của từng module trên bộ dữ liệu công khai, kết quả kiểm thử trên lab ảo và nhận xét.

3.1. MÔ HÌNH TRIỂN KHAI

3.1.1. Môi trường triển khai

Lab ảo gồm 7 máy trong mạng 192.168.50.0/24, mỗi máy là một network namespace nối vào một bridge. Mọi gói qua bridge được sao chép (mirror) về máy giám sát. Mạng không có đường ra ngoài.

Bảng 3.1. Các máy trong lab ảo

Địa chỉ	Vai trò
192.168.50.10	Máy giám sát: nhận bản sao gói tin, chạy tcpdump và cảm biến
192.168.50.20	Máy thử nghiệm: nguồn của quét cổng và DoS
192.168.50.30	Máy chủ dịch vụ (Nginx)
192.168.50.41 – .43	Máy trạm duyệt web; đóng vai bot mô phỏng trong kịch bản botnet
192.168.50.50	Máy điều khiển mô phỏng

3.1.2. Các công cụ sử dụng

- Nginx phục vụ trang web; script Python sinh lưu lượng duyệt web bình thường.
- Nmap quét cổng 1–1024 (chậm: giãn cách 0,5 giây; nhanh: -T4).
- Script tải kết nối ở ba mức 50, 200, 600 kết nối mỗi giây; hping3 gửi SYN (không giả mạo nguồn). Mỗi đợt tối đa 60 giây.
- Script bot mô phỏng: gọi máy điều khiển theo chu kỳ 30–60 giây (tập trung) hoặc gửi UDP cho nhau theo chu kỳ 8–30 giây (ngang hàng).

3.1.3. Cấu hình hệ thống

Tham số chính: cửa sổ 10 giây trượt 2 giây và 120 giây trượt 10 giây; timeout flow 60 giây (nhàn rỗi), 120 giây (tối đa), 10 giây (sau đóng kết nối); thời gian chờ

bắt tay 3 giây ở cấu hình mặc định và 1 giây ở cấu hình lab. Đề tài đã trích xuất lại CIC-IDS2017 và huấn luyện lại cho 7 cấu hình đổi một tham số: macro-F1 trên tập kiểm định nằm trong khoảng 0,932–0,938 (hiện tại 0,935), nên giữ nguyên bộ tham số.

3.2. KẾT QUẢ THỰC NGHIỆM TRÊN BỘ DỮ LIỆU CÔNG KHAI

3.2.1. Kịch bản 1: Kiểm tra bộ đọc gói tin

Bảng gói tin do bộ đọc tự viết tạo ra được so với Wireshark trên 5 bản thu thật và 2 file tổng hợp: khớp mọi trường của 4 571 135 gói. Bảng log khớp mọi ô của 470 dòng log do Nginx ghi.

3.2.2. Kịch bản 2: Module phát hiện bất thường trên CIC-IDS2017

Bảng 3.2. Kết quả module Gaussian trên tập kiểm tra (105 361 cửa sổ, 5,1% là tấn công)

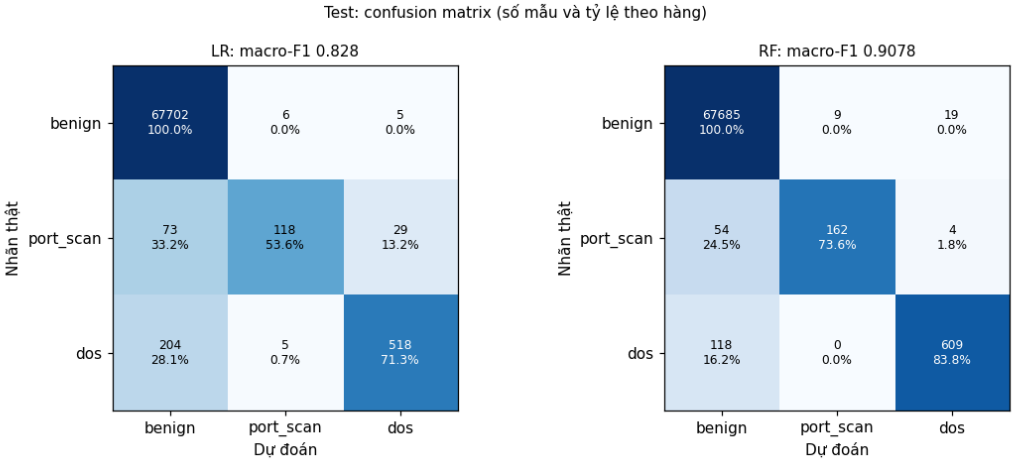
Precision	Recall	F1	Tỷ lệ báo động giả	AUC
0,733	0,727	0,730	1,42%	0,977

Module nhận ra phần lớn tấn công ồn ào nhưng báo động giả còn nhiều (khoảng 17 đợt mỗi giờ) và bỏ sót các tấn công trông giống lưu lượng bình thường, nên không dùng một mình được.

3.2.3. Kịch bản 3: Module phân loại tấn công trên CIC-IDS2017

Bảng 3.3. So sánh hai mô hình phân loại

	Logistic Regression	Random Forest (chọn)
Macro-F1 tập kiểm tra	0,828	0,908
Recall port_scan	53,6%	73,6%
Recall dos	71,3%	83,8%
Cửa sổ bình thường bị báo tấn công	11 / 67 713	28 / 67 713



Hình 3.1. Ma trận nhầm lẫn của hai mô hình phân loại trên tập kiểm tra

Random Forest đạt macro-F1 0,935 trên tập kiểm định và 0,908 trên tập kiểm tra. Phần bỏ sót chủ yếu là DoS HTTP chậm: giữa hai đợt gửi, cửa sổ 10 giây của máy bị tấn công trông như bình thường. Một lớp bổ sung giữ nhãn dos theo máy đã được đo thử: recall dos trên tập kiểm tra tăng từ 0,838 lên 0,938; lớp này chưa được bật trong hệ thống.

3.2.4. Kịch bản 4: Module botnet trên CTU-13

Bảng 3.4. Phát hiện máy bot trên tập kiểm tra CTU-13 (kịch bản 1, 2, 6, 8, 9)

	Random Forest (chọn)	**Logistic Regression**
Precision / Recall / F1	0,971 / 0,678 / 0,798	0,949 / 0,132 / 0,232
Báo nhầm máy bình thường	1,6%	0,5%

Các họ bot trong tập kiểm tra không có trong tập huấn luyện. Quy tắc nhận dạng topology gán đúng kiểu tập trung cho 99,9% cửa sổ bot của tập kiểm tra.

3.2.5. Kịch bản 5: Pipeline offline và cảm biến realtime

Pipeline chạy trên bốn đoạn PCAP của CIC-IDS2017 nằm trong khoảng kiểm tra (khoảng 1,1 triệu gói); ở chế độ độc lập không đợt quét cổng, Slowloris hay Hulk nào bị bỏ sót. Khi phát lại bốn đoạn này qua cảm biến realtime, cảnh báo của module bất thường và module phân loại giống hệt kết quả offline.

3.3. KẾT QUẢ THỰC NGHIỆM TRÊN LAB ẢO

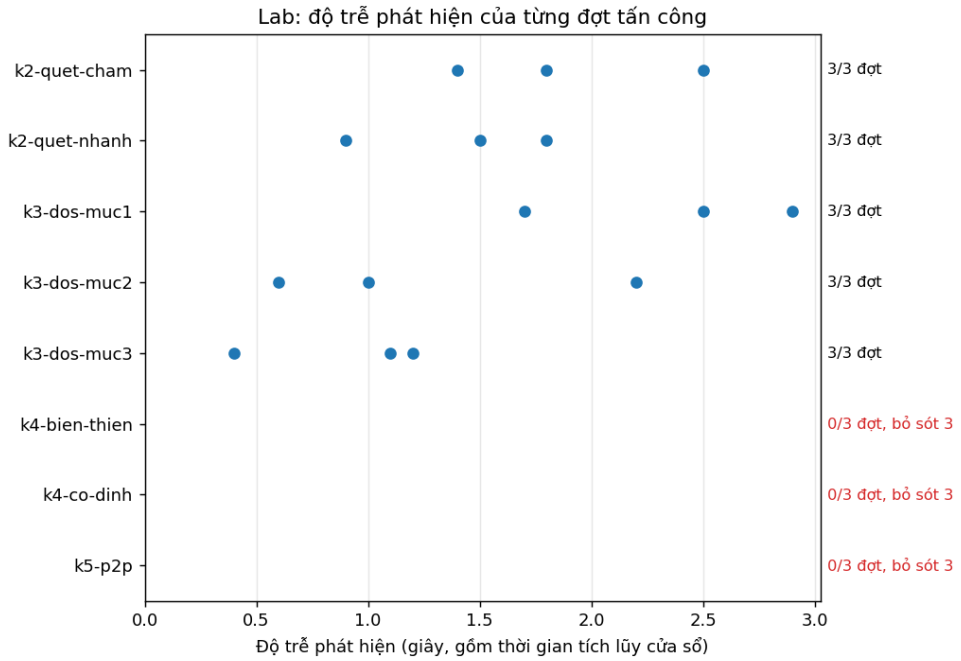
Đã thu 177 lần chạy: 33 lần để học, 11 lần để chọn ngưỡng, 99 lần để kiểm tra, 16 lần thí nghiệm bổ sung và 18 lần của các biến thể kiểm tra khái quát. Không lần nào mất gói ở máy giám sát.

Bảng 3.5. Các kịch bản lab

Kịch bản	Biến thể	Nội dung
1. Bình thường	k1-binh-thuong	Ba máy trạm duyệt web
2. Quét cổng	k2-quet-cham, k2-quet-nhanh	Nmap quét cổng 1–1024 của máy chủ
3. DoS	k3-dos-muc1, muc2, muc3	Tải kết nối 50 / 200 / 600 kết nối mỗi giây trong 60 giây
4. Botnet tập trung	k4-co-dinh, k4-bien-thien, k4-doi-chung	Ba bot gọi máy điều khiển theo chu kỳ; đối chứng: gọi định kỳ lành tính tới máy chủ dịch vụ
5. Botnet ngang hàng	k5-p2p, k5-doi-chung	Ba bot gửi UDP cho nhau; đối chứng: các máy chia sẻ khối dữ liệu lớn

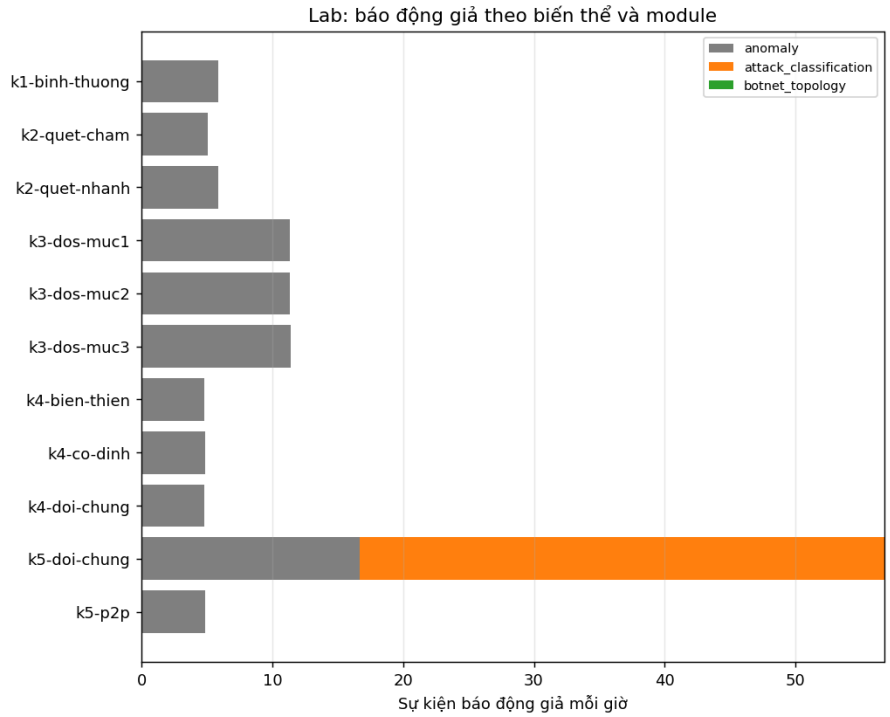
3.3.1. Kịch bản 1: Mô hình học từ dữ liệu công khai, chạy trên lab

Mô hình và ngưỡng đã khóa từ CIC-IDS2017 và CTU-13 được chấm trên 33 lần kiểm tra của lab, không chỉnh gì.



Hình 3.2. Độ trễ phát hiện của từng đợt tấn công với mô hình học từ dữ liệu công khai

– Quét cổng 6/6 đợt và DoS 9/9 đợt được phát hiện; độ trễ tới cuối cửa sổ 0,4–2,9 giây, cảm biến realtime phát cảnh báo sau 3,5–6,3 giây (trung vị 4,6 giây).
– Botnet bị bỏ sót 9/9 đợt: điểm cao nhất mô hình cho bot của lab là 0,084, dưới ngưỡng 0,1.
– Báo động giả nhiều: module bất thường báo máy chủ dịch vụ suốt cả bản thu; module phân loại coi việc chia sẻ khối dữ liệu lớn là DoS.



Hình 3.3. Báo động giả theo biến thể và module với mô hình học từ dữ liệu công khai

3.3.2. Kịch bản 2: Học lại mô hình trên dữ liệu lab

Ba module được học lại trên các lần chạy để học của lab (ba lần mỗi biến thể), chọn ngưỡng trên các lần riêng, rồi chấm trên 33 lần kiểm tra mới thu sau khi học.

Bảng 3.6. Kết quả trên 33 lần kiểm tra mới của lab

	Mô hình học từ dữ liệu công khai	**Mô hình học trên lab**
Đợt tấn công phát hiện	15/24	24/24
Quét cổng / DoS / botnet	6/6, 9/9, 0/9	6/6, 9/9, 9/9
Sự kiện báo động giả	58	0
Macro-F1 theo cửa sổ	—	0,9989

Topology ngang hàng gán đúng	—	98,2%
Topology tập trung gán đúng	—	100%

Lần học đầu tiên chỉ dùng một lần chạy mỗi biến thể: vẫn phát hiện 24/24 đợt nhưng còn báo động giả trên kịch bản chia sẻ dữ liệu. Tăng lên ba lần chạy mỗi biến thể thì hết báo động giả.

3.3.3. Kịch bản 3: Kiểm tra khái quát

Bảng 3.7. Mô hình lab trên các biến thể chưa từng học

Biến thể	Nội dung	Kết quả
Đổi vai trò máy	Bot là các máy khác, máy điều khiển khác, cổng và chu kỳ khác	6/6 đợt, 0 báo động giả; một bot bị sót ở 2/3 lần chạy ngang hàng
SYN flood	hping3 gửi SYN tới cổng 80 trong 60 giây, ba mức	9/9 đợt, 0 báo động giả
Chấm chéo với CTU-13	Mô hình botnet của lab chấm trên tập kiểm tra CTU-13	Recall 0

Mô hình lab nhận ra bot ở vai trò, cổng và chu kỳ chưa từng thấy, nhưng không nhận ra bot thật của CTU-13. Kết quả 24/24 vì vậy chỉ có nghĩa trong lab với bot mô phỏng.

3.3.4. Kịch bản 4: Cảm biến realtime bắt trực tiếp (demo)

Cảm biến chạy trên máy giám sát của lab, dùng bộ mô hình lab, bắt gói trực tiếp trong lúc kịch bản chạy. Kết quả của ba lần chạy demo ngày 13/11/2026:

Bảng 3.8. Kết quả demo với cảm biến bắt trực tiếp

Kịch bản	Cảnh báo	Độ trễ	Báo động giả
Bình thường (khoảng 2 phút)	Không có	—	0
Nmap quét nhanh	10 cảnh báo port_scan cho máy quét và máy bị quét	3,1 giây	0
Tải kết nối 60 giây	70 cảnh báo dos, dừng 10 giây sau khi tải dừng	1,5 giây	0

```
>> 10:33:17  CẢNH BÁO PORT_SCAN  host 192.168.50.20   điểm 0.9533
>> 10:33:17  CẢNH BÁO PORT_SCAN  host 192.168.50.30   điểm 0.9933
Tấn công thật: port_scan từ 192.168.50.20 vào 192.168.50.30, 10:24:48
=> PHÁT HIỆN: 10 cảnh báo port_scan; cảnh báo đầu tiên lúc 10:24:51,
   sau khi tấn công bắt đầu 3.1 giây
Cảnh báo có loại tấn công nằm ngoài đợt tấn công (báo động giả): 0
```

Hình 3.4. Trích màn hình demo quét cổng: cảnh báo và phần tổng kết

Trong thí nghiệm bổ sung, cảm biến bắt trực tiếp không mất gói ở tải tới khoảng 2 900 gói mỗi giây.

3.4. NHẬN XÉT ĐÁNH GIÁ KẾT QUẢ

Qua kết quả thực nghiệm, có những nhận xét như sau:

- Quét cổng và DoS tải kết nối có dấu hiệu giống nhau ở mọi mạng (nhiều cổng đích, nhiều kết nối không hoàn tất, nhiều kết nối mỗi giây), nên mô hình học từ CIC-IDS2017 vẫn phát hiện được trên lab.
- Mô hình botnet học từ CTU-13 không chuyển sang lab: bot của CTU-13 ồn ào (spam, DDoS), bot của lab chỉ gọi định kỳ với rất ít lưu lượng. Ngược lại, mô hình học trên lab không nhận ra bot của CTU-13.
- Báo động giả của mô hình cũ trên lab có cùng một nguyên nhân: mô hình chưa từng thấy mạng này (máy chủ web, truyền dữ liệu nội bộ).
- Học lại trên chính mạng cần giám sát giải quyết cả hai vấn đề trong lab: 24/24 đợt, không báo động giả. Lab dễ hơn mạng thật: chỉ 7 máy, lưu lượng bình thường do bộ sinh tạo ra nên đều đặn.
- Độ trễ của quét cổng và DoS là vài giây vì cửa sổ 10 giây trượt mỗi 2 giây; giảm thời gian chờ bắt tay từ 3 xuống 1 giây làm cảnh báo sớm hơn khoảng 2 giây mà không đổi kết quả phát hiện.
- Module Gaussian không đủ dùng một mình trên CIC-IDS2017; nó có ích như một tín hiệu bổ sung.

3.5. Kết chương

Chương này đã trình bày môi trường lab ảo, kết quả của ba module trên CIC-IDS2017 và CTU-13, kết quả kiểm thử trên lab với mô hình cũ và mô hình học lại, kiểm tra khái quát và kết quả demo realtime.

KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

1. KẾT QUẢ ĐẠT ĐƯỢC

Đề tài đã đạt được những kết quả sau:

- Xây dựng được trọn chuỗi xử lý từ gói tin tới cảnh báo, chạy được offline trên file PCAP và realtime trên card mạng, dùng cùng một đoạn mã tính đặc trưng.
- Bộ đọc gói tin tự viết khớp Wireshark ở mọi trường của 4,57 triệu gói.
- Module phân loại (Random Forest) đạt macro-F1 0,908 trên tập kiểm tra CIC-IDS2017; module botnet đạt precision 0,971, recall 0,678 trên tập kiểm tra CTU-13 với các họ bot chưa thấy lúc học; module Gaussian đạt F1 0,730.
- Dựng được lab ảo 7 máy và bộ chạy kịch bản tự ghi nhãn chuẩn; thu 177 lần chạy.
- Trên lab, bộ mô hình học lại phát hiện 24/24 đợt tấn công trên các lần kiểm tra mới, không báo động giả; vẫn phát hiện khi đổi vai trò máy (6/6) và với SYN flood (9/9).
- Cảm biến realtime phát cảnh báo quét cổng và DoS sau khoảng 1,5–3 giây trong demo.
- Mã nguồn có 444 kiểm thử tự động; 73 quyết định kỹ thuật được ghi lại kèm lý do.

Tuy nhiên, vẫn còn tồn tại các vấn đề như sau:

- Mới kiểm thử trên lab ảo; chưa chạy trên lab vật lý và chưa cài trên Kali Linux.
- Mô hình không chuyển giữa các mạng: mô hình botnet của lab cho recall 0 trên CTU-13.
- DoS HTTP chậm còn bị bỏ sót (recall Slowhttptest 0,66 trên CIC-IDS2017); lớp giữ nhãn dos đã đo nhưng chưa bật.
- Module Gaussian báo động giả nhiều trên CIC-IDS2017.

- Chưa có dữ liệu cho brute-force và khai thác lỗ hổng.

2. KIẾN NGHỊ VÀ HƯỚNG PHÁT TRIỂN

Một số hướng phát triển của đề tài như sau:

- Dựng lab vật lý với switch có cổng mirror, cài hệ thống trên Kali Linux và so kết quả với lab ảo.
- Bật lớp giữ nhãn dos theo máy trong pipeline và cảm biến realtime.
- Thu thêm dữ liệu học cho SYN flood và các biến thể đổi vai trò máy.
- Thử độ nhạy của độ dài cửa sổ; bổ sung các loại tấn công khác.

TÀI LIỆU THAM KHẢO

[1] I. Sharafaldin, A. H. Lashkari, A. A. Ghorbani (2018), "Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization", Proceedings of the 4th International Conference on Information Systems Security and Privacy (ICISSP).

[2] S. García, M. Grill, J. Stiborek, A. Zunino (2014), "An empirical comparison of botnet detection methods", Computers & Security, vol. 45, pp. 100–123.

[3] G. Engelen, V. Rimmer, W. Joosen (2021), "Troubleshooting an Intrusion Detection Dataset: the CICIDS2017 Case Study", IEEE Security and Privacy Workshops (SPW).

[4] L. Breiman (2001), "Random Forests", Machine Learning, vol. 45, no. 1, pp. 5–32.

[5] O. Ledoit, M. Wolf (2004), "A well-conditioned estimator for large-dimensional covariance matrices", Journal of Multivariate Analysis, vol. 88, no. 2, pp. 365–411.

[6] F. Pedregosa et al. (2011), "Scikit-learn: Machine Learning in Python", Journal of Machine Learning Research, vol. 12, pp. 2825–2830.

Internet

[7] https://www.unb.ca/cic/datasets/ids-2017.html

[8] https://www.stratosphereips.org/datasets-ctu13

[9] https://nmap.org

[10] https://www.wireshark.org

[11] https://github.com/nkhhieu123/ml-nids

PHỤ LỤC

1. Lệnh chạy demo

```
demo\0_kiem_tra.bat          kiểm tra môi trường
demo\1_demo_quet_cong.bat    quét cổng bằng Nmap, cảm biến realtime
demo\2_demo_dos.bat          tải kết nối 60 giây
demo\3_demo_binh_thuong.bat  chỉ có lưu lượng bình thường
demo\4_ket_qua_da_luu.bat    in bảng kết quả đã lưu
```

2. Lệnh chạy pipeline và cảm biến

```
cd src
python -m nids.thuc_nghiem <file.pcap> --net 192.168.50.0/24 \
    --nhat-ky ../data/run_logs --config ../config/lab.yaml
python -m nids.realtime --iface eth0 --net 192.168.50.0/24 \
    --out <thư mục> --config ../config/lab.yaml
```